

INSuRE Fall 2023 Final Presentation Malware Similarity



- Sponsor: **MITRE**

- **Technical Director**

Frank

Posluszny(malwarefrank@mitre.org)

- **Faculty**

Brian Ricks(bwr031000@utdallas.edu)

Team

1. Venu Gopal Reddy Yendreddy

(vxy210021@utdallas.edu)

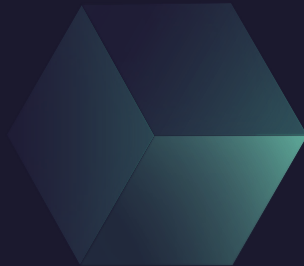
Computer Science, UTD



2. Neelima Reddy Kapa

(nxk220027@utdallas.edu)

Computer Science, UTD



3. Navya Teja Gajula

(nxg220002@utdallas.edu)

Computer Science, UTD

Description

- Our project, guided by MITRE's Technical Director Frank Posluszny, delves into the fascinating realm of cybersecurity.
- We're on a mission to connect professionals working on similar malware projects across the country. By identifying the unique fingerprints left by the Malware Development Life Cycle (MDLC), we aim to foster collaboration and reduce duplication of effort.
- Through this project, we envision a future where cybersecurity experts come together seamlessly, enhancing our collective ability to safeguard digital landscapes.
- This initiative not only bolsters our understanding of cyber threats but also propels us towards a more secure and interconnected digital world

Motivation

1. Analyzing malware behavior for pattern recognition.
2. Evaluating the effectiveness of current anti-malware solutions.
3. Implementing proactive measures to safeguard against evolving threats.
4. Investigating novel approaches for malware identification and mitigation.

Goals

Uncovering Malware Relationships:

1. Investigating the connections between different malware strains.
2. Tracing the evolution of malware families and their variants.

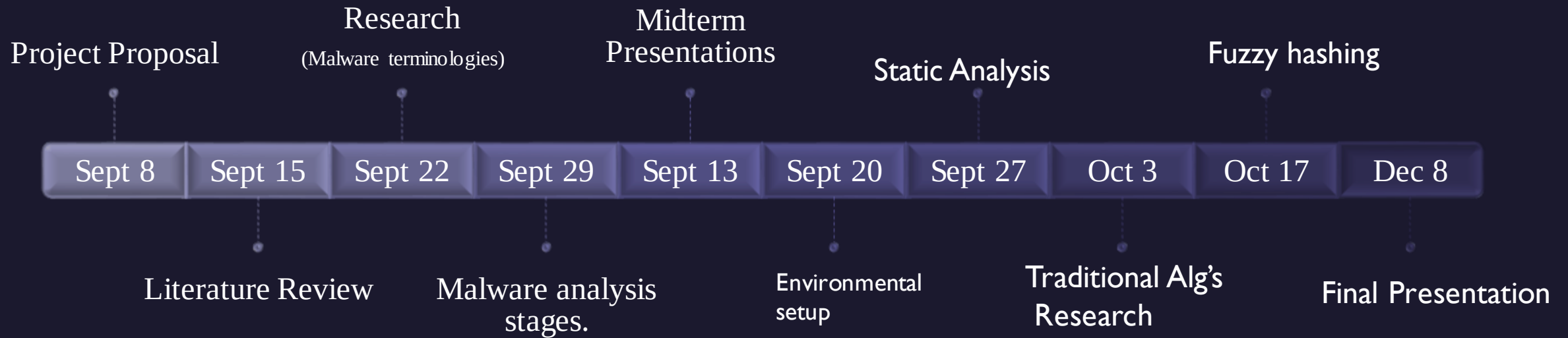


Behavioral Profiling of Malware:

1. Analyzing the actions and interactions of various malware types.
2. Identifying patterns in their behavior for predictive analysis.



Timeline



Literature Review

1. Malware Similarity Analysis: An adversary perspective - Frank Posluszny, March 2020
2. Software Forensics: Research Paper - Eugene H. Spafford and Stephen A. WeebeT
3. Automatic analysis of malware behavior using machine learning: Research Article - [Rieck, Konrad, Trinius, Philipp, Willems, Carsten, Holz, Thorsten](#)

Malware Similarity Analysis - An adversary perspective

The article presents the Malware Development Life Cycle (MDLC), mirroring the Software Development Life Cycle with eight phases. It discusses each stage and its relevance to malware analysis, emphasizing MDLC's utility in identifying similarities among malware instances, and aiding practitioners in understanding adversaries' tactics.

- **Challenges:** Malware Diversity, Data Collection, Integration into Existing Frameworks, Measurement of Artifacts
- This paper addresses these challenges by Malware Similarity Identification, Data Integration, Improved Defenses.

MDLC



Figure 1 : Malware Development Life Cycle (simplified)

Software Forensics — Can we track code to its authors?

The paper emphasizes that hackers and virus authors rely on network anonymity, making it hard to catch them. To address this, it recommends reducing anonymity through techniques like detailed session logging and enhanced network protocols with user identification.

- **Challenges:** Anonymity in Cybercrimes, Effectiveness of Countermeasures, Authorship Identification, Sample Selection
- This paper addresses these challenges by Reducing Anonymity, Authorship Identification, Sample Selection



Automatic analysis of malware behavior using machine learning

The paper deals with the persistent problem of malware in computer security. It introduces a machine learning system to analyze malware behavior, enabling the detection of new types and categorizing unknown malware. Additionally, it offers an efficient method for this analysis that maintains accuracy while reducing runtime demands.

- Challenges: Malware Diversity, Real-Time Analysis, Clustering and Classification, Runtime Overhead.
- The challenges are addressed by Machine Learning, Incremental Analysis, Behavior-Based Analysis, Accurate Discovery

Static Analysis



Unraveling Intricacies through Static Examination

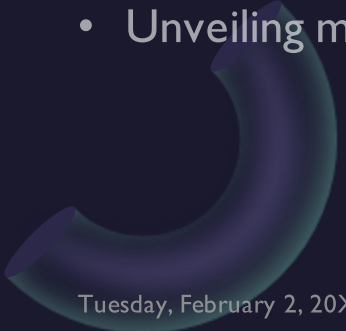
Functionality:

- Static analysis involves a meticulous dissection of the binary executable, enabling a comprehensive examination of structure, metadata, and potential functionalities—without code execution.

Challenges:

- Grappling with formidable challenges: obfuscated code structures, polymorphic malware variants, and anti-analysis mechanisms strategically designed to impede straightforward static scrutiny.

Goal:

- Unveiling malware's capabilities, intentions, and potential impact without triggering malicious behavior.
- 

Focus:

- Primary focus on understanding static attributes: scrutinizing file structures, identifying distinctive code patterns, and analyzing resource utilization within the binary.

Tools that can be Utilized:

- **PEStudio:**

- Fundamental tool for examining Portable Executable (PE) files, providing insights into file composition and potential threats.

- **IDA Pro:**

- Advanced disassembler aiding in dissecting and understanding the assembly code of the malware.

- **Radare2:**

- Open-source reverse engineering framework offering diverse tools for static analysis and disassembly.



imports (155)	flag (29)	first-thunk-original (INT)	first-thunk (IAT)	hint	group (11)	technique (12)
WritePrivateProfileStringA	x	0x00007770	0x00007770	924 (0x039C)	registry	-
RegSetValueExA	x	0x00008034	0x00008034	505 (0x01F9)	registry	T1112 Modify Registry
RegEnumKeyA	x	0x00008012	0x00008012	469 (0x01D5)	registry	T1012 Query Registry
RegDeleteKeyA	x	0x00008078	0x00008078	464 (0x01D0)	registry	T1485 Data Destruction
RegDeleteValueA	x	0x00008066	0x00008066	466 (0x01D2)	registry	T1485 Data Destruction
RegCreateKeyExA	x	0x00008046	0x00008046	461 (0x01CD)	registry	T1112 Modify Registry
SearchPathA	x	0x00007894	0x00007894	720 (0x02D0)	reconnaissance	-
MoveFileA	x	0x000078CA	0x000078CA	612 (0x0264)	file	T1105 Remote File Copy
SetFileAttributesA	x	0x00007928	0x00007928	782 (0x030E)	file	-
RemoveDirectoryA	x	0x00007A70	0x00007A70	698 (0x02BA)	file	-
WriteFile	x	0x00007748	0x00007748	919 (0x0367)	file	-
FindNextFileA	x	0x0000770E	0x0000770E	211 (0x00D3)	file	-
FindFirstFileA	x	0x000076FC	0x000076FC	201 (0x00C5)	file	-
DeleteFileA	x	0x000076EE	0x000076EE	124 (0x007C)	file	-
SHGetPathFromIDListA	x	0x00007FC0	0x00007FC0	188 (0x00BC)	file	-
SHBrowseForFolderA	x	0x00007FAA	0x00007FAA	121 (0x007D)	file	-
SHGetFileInfoA	x	0x00007F98	0x00007F98	172 (0x00AC)	file	-
SHFileOperationA	x	0x00007F74	0x00007F74	154 (0x009A)	file	-
SHGetSpecialFolderLocation	x	0x00007FD8	0x00007FD8	195 (0x00C3)	file	-
GetCurrentProcess	x	0x00007988	0x00007988	314 (0x013A)	process	-
CreateProcessA	x	0x00007A5E	0x00007A5E	96 (0x0060)	process	-
GetExitCodeProcess	x	0x000077EA	0x000077EA	338 (0x0152)	process	-
ShellExecuteA	x	0x00007F88	0x00007F88	263 (0x010B)	file	-
CloseClipboard	x	0x00007DE0	0x00007DE0	66 (0x0042)	file	-
SetClipboardData	x	0x00007DF2	0x00007DF2	585 (0x0249)	file	-
EmptyClipboard	x	0x00007E06	0x00007E06	193 (0x00C1)	file	-
OpenClipboard	x	0x00007E18	0x00007E18	501 (0x01F5)	file	-
SetCurrentDirectoryA	x	0x000078D6	0x000078D6	767 (0x02FB)	file	-

www.initor.com - [c:\users\acer\onedrive\desktop\specialtopics\nirsoft\20161124\webvideocap_setup.exe] - [read-only]

indicator (21)	detail	level
file > signature	Nullsoft PiMP Stub -> SFX	1
file > embedded	signature: Nullsoft, location: overlay, offset: 0x0000B600, size: 54846 (byt...	1
virustotal > score	2/71	1
imports > flag > count	29	1
overlay > file-ratio	54.07%	2
overlay > size	54846 bytes	2
overlay > entropy	7.997	2
file > checksum	0x00000000	2
sections > virtualized	.ndata	2
groups > API	file reconnaissance diagnostic execution dynamic-library memory...	2
string > URL	http://nsis.sf.net/NSIS_Error	2
mitre > technique	T1105 T1497 T1124 T1057 T1106 T1083 T1082 T1485 T1055 T111...	2
file > entropy	7.487	3
file > sha256	BE60CC9B261AB3C44D91E5EE0B4E9F24894DB6F9987D1A28F70C4411261...	3
file > size	101438 bytes	3
rich-header > checksum	0xFB2414A1	3
rich-header > offset	0x00000080	3
rich-header > footprint	F4079DB2511D51EF8BE4946CD0AC9E319050929C216B36EBF412E10D1D0...	3
file > tooling	Visual Studio 2003	3
file > subsystem	GUI	3
imports > ordinal > count	1	3



Traditional Hashing Techniques

- In the Analysis of Malware samples, experts use Hashing algorithms to generate hash values for files.
- These help in identifying including identifying known malware samples, verifying file integrity, and facilitating data analysis.
- **Most Commonly Used hashing : MD5 , SHA-1, SHA-256 , SSDEEP, CRC32, ImpHash, TLSH.**
- **Why not General Hashing?**
 - **Collision Vulnerability**
 - **Limited Hash Length**



CTPH

- Hashing algorithm designed to identify similar but not necessarily identical files.
- How it Works ?
 - **Piecewise Hashing**
 - **Context Triggering**
 - **Similarity Calculation**
 - **Fuzzy Hashing**

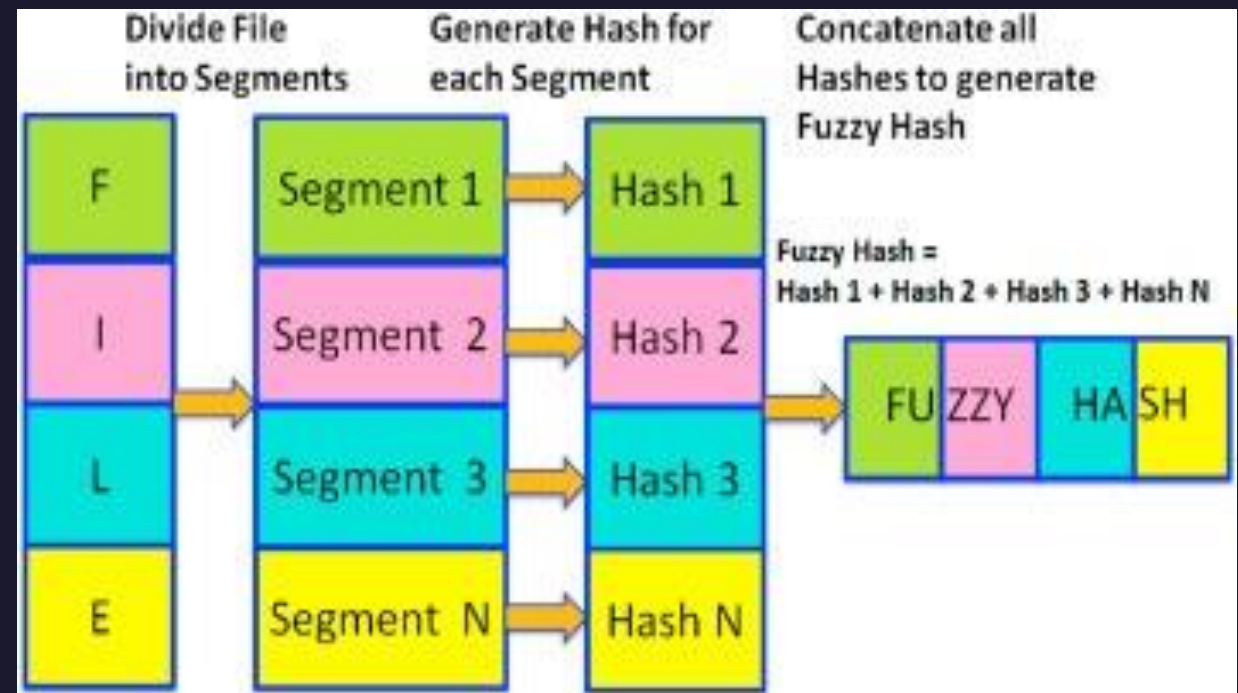


Fuzzy Hashing for Malware Clustering

One method for locating similar or identical content within files is fuzzy hashing. Instead of producing a hash that exactly matches a binary file, fuzzy hashing produces a hash that captures the structure and content of the file.

These fuzzy hashes are produced by ssdeep using context-triggered piecewise hashing. Even if two files are not identical, their content can be identified by their hash.

A popular tool for fuzzy hashing that offers a reliable similarity detection solution is ssdeep.



Using ssdeep tool for Fuzzy Hashing

In malware analysis, ssdeep is useful for grouping together related malware samples.

Ssdeep assists in clustering malware variants with comparable traits. It helps to clarify the connections between various malware strains.

We installed ssdeep tool and did the setup. We are trying to generate fuzzy hashes by running this on a directory containing malware samples which were provided by Frank. Will deliver the results prior to the deadline, which is the following week.



SSDEEP - Fuzzing Hashing Techniques
to Detect Unknown Malware

Fuzzy Hashing Similarity Test using ssdeep



```
@Venus-Air FuzzyHashing % ssdeep -h
ep version 2.14.1 by Jesse Kornblum and the ssdeep Project
copyright information, see man page or README.TXT.

e: ssdeep [-m file] [-k file] [-dpgvrsblcxa] [-t val] [-h|-V] [FILES]
Match FILES against known hashes in file
Match signatures in FILES against signatures in file
Directory mode, compare all files in a directory
Pretty matching mode. Similar to -d but includes all matches
Cluster matches together
Verbose mode. Displays filename as its being processed
Recursive mode
Silent mode; all errors are suppressed
Uses only the bare name of files; all path information omitted
Uses relative paths for filenames
Prints output in CSV format
Compare FILES as signature files
Display all matches, regardless of score
Only displays matches above the given threshold
Display this help message
Display version number and exit
@Venus-Air FuzzyHashing % ls
Email1.pages      spamEmail2.pages      spamEmail3.pages      spamEmail4.pages      spamEmail5.pages
@Venus-Air FuzzyHashing % ssdeep * > fuzzyHashingSimilarity.ssd
@Venus-Air FuzzyHashing % cat fuzzyHashingSimilarity.ssd
ep,1.1--blocksize:hash:hash,filename
:6dsurj2MD+oIfk3jHPWjTTrT+jzZ4qUf6WL7Aj:Lun2ujIfk3zgT+XzyVLkj,"/Users/venu/Desktop/FuzzyHashing/spam
:Hsurj2MDvoLs/ujK3GGQXtBPuaLW21pkL:Mun2uwLs/AK3GGQTrTU,"/Users/venu/Desktop/FuzzyHashing/spamEmail2.
:kj0surj2MDvogN9LoD9NfPOWdYbQdfBnX78fKJn1w:Kxun2uwgN9Li9NnO+4KfBnX78fQw,"/Users/venu/Desktop/FuzzyHa
:dU1LsqZ0Rk3sZ4bYVdTOxOR+lJ29niyhS4NHtTxk0n2ZxobqJKqF35u8zu+/3bxm:mhhHsurj2MDvouJl3u8hLAYBM,"/Users/
:fHk3sZ4bYVdTOxOR+lJ29niyhS4NHtTxk0n2Zxo7QAzcFhqtCzrdNi0jvTLDwAmP:+surj2MDvoMam6CzBISP0Am5fBuOt,"/Us
:jsurj2MD+ohZLWPsNfPOWdYbQdfBnX78fKJnFm:Yun2ujhZLksNnO+4KfBnX78f4m,"/Users/venu/Desktop/FuzzyHashing
```

- We have installed ssdeep and used six spam emails as test data.
- Subsequently, calculated the hash code for each email and saved all the hash codes for the six files in a file fuzzyHashingSimilarity.ssd.
- The next step involves checking the similarity between these files.

```

[venu@Venus-Air FuzzyHashing % ssdeep -m fuzzyHashingSimilarity.ssd * -s
/Users/venu/Desktop/FuzzyHashing/spamEmail1.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail1.pages (100)
/Users/venu/Desktop/FuzzyHashing/spamEmail1.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail2.pages (35)
/Users/venu/Desktop/FuzzyHashing/spamEmail1.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail3.pages (35)
/Users/venu/Desktop/FuzzyHashing/spamEmail1.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail4.pages (36)
/Users/venu/Desktop/FuzzyHashing/spamEmail1.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail5.pages (35)
/Users/venu/Desktop/FuzzyHashing/spamEmail1.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail6.pages (38)
/Users/venu/Desktop/FuzzyHashing/spamEmail2.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail1.pages (35)
/Users/venu/Desktop/FuzzyHashing/spamEmail2.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail2.pages (100)
/Users/venu/Desktop/FuzzyHashing/spamEmail2.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail3.pages (36)
/Users/venu/Desktop/FuzzyHashing/spamEmail2.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail4.pages (49)
/Users/venu/Desktop/FuzzyHashing/spamEmail2.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail5.pages (40)
/Users/venu/Desktop/FuzzyHashing/spamEmail2.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail6.pages (35)
/Users/venu/Desktop/FuzzyHashing/spamEmail3.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail1.pages (35)
/Users/venu/Desktop/FuzzyHashing/spamEmail3.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail2.pages (36)
/Users/venu/Desktop/FuzzyHashing/spamEmail3.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail3.pages (100)
/Users/venu/Desktop/FuzzyHashing/spamEmail3.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail4.pages (35)
/Users/venu/Desktop/FuzzyHashing/spamEmail3.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail5.pages (35)
/Users/venu/Desktop/FuzzyHashing/spamEmail3.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail6.pages (77)
/Users/venu/Desktop/FuzzyHashing/spamEmail4.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail1.pages (36)
/Users/venu/Desktop/FuzzyHashing/spamEmail4.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail2.pages (49)
/Users/venu/Desktop/FuzzyHashing/spamEmail4.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail3.pages (35)
/Users/venu/Desktop/FuzzyHashing/spamEmail4.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail4.pages (100)
/Users/venu/Desktop/FuzzyHashing/spamEmail4.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail5.pages (63)
/Users/venu/Desktop/FuzzyHashing/spamEmail4.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail6.pages (36)
/Users/venu/Desktop/FuzzyHashing/spamEmail5.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail1.pages (35)
/Users/venu/Desktop/FuzzyHashing/spamEmail5.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail2.pages (40)
/Users/venu/Desktop/FuzzyHashing/spamEmail5.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail3.pages (35)
/Users/venu/Desktop/FuzzyHashing/spamEmail5.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail4.pages (63)
/Users/venu/Desktop/FuzzyHashing/spamEmail5.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail5.pages (100)
/Users/venu/Desktop/FuzzyHashing/spamEmail5.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail6.pages (35)
/Users/venu/Desktop/FuzzyHashing/spamEmail6.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail1.pages (38)
/Users/venu/Desktop/FuzzyHashing/spamEmail6.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail2.pages (35)
/Users/venu/Desktop/FuzzyHashing/spamEmail6.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail3.pages (77)
/Users/venu/Desktop/FuzzyHashing/spamEmail6.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail4.pages (36)
/Users/venu/Desktop/FuzzyHashing/spamEmail6.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail5.pages (35)
/Users/venu/Desktop/FuzzyHashing/spamEmail6.pages matches fuzzyHashingSimilarity.ssd:/Users/venu/Desktop/FuzzyHashing/spamEmail6.pages (100)
/Users/venu/Desktop/FuzzyHashing/-s: No such file or directory

```

Similarity Found using ssdeep

- The files were compared using the ssdeep tool for Fuzzy Hashing, revealing the percentage of similarity.
- This approach enables Identification of similarities b/w emails, contributing to the detection of digital forensics in the data.
- Throughout the semester, we explored various techniques for identifying similarities & gained valuable insights.

Future Work

- Utilizing ssdeep Fuzzy hashing for similarity analysis has revealed issues in accurately assessing similarities among distinct images, despite observable similarities. Investigating the root causes of these discrepancies and implementing solutions stands as a prospective avenue for future research.
- Additionally, exploring other techniques that are known for having best time complexity may provide better accuracy when detecting similarities. This points to an approach for future research that focuses on improving similarity analysis's efficiency across different datasets.



Challenges



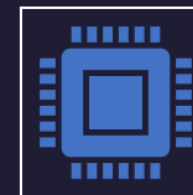
1. Less number of teammates in our group.



2. Limited and varying domain specific knowledge among team members.



3. Despite a large amount of available data, there is currently a need for deeper analysis to derive meaningful insights.



4. Windows and Linux Virtual environment support on Windows and M1 Mac Machines.



Any Questions ?

Thank You

